소프트웨어개발보안경진대회 개발기획서

지원트랙	☐ **트랙A : 자유주제 부문** ☐ **트랙B : 기술혁신 부문** ▨ **트랙C : 공공활용 부문**		
팀명	반납한연휴	**개발언어**	python
프로젝트명	개인정보 유출 대응 헬프데스크		
프로젝트 소개	개인정보 유출 사고 발생 시 기업·정부기관의 공식 발표를 기반으로 유출 항목을 확인하고, 상황 설문과 유출 통지문 OCR 인식을 통해 맞춤형 대응 가이드를 제공하여 검증되지 않은 정보로 인한 혼란과 스미싱 등 2차 피해를 줄이는 서비스		
팀 소개 및 팀원별 역할	정보보호에 관심 있는 관련 전공 대학생 4인팀으로, 보안을 설계 단계부터 반영한 서비스 개발을 목표로 함. 기획·디자인 1인 (서비스 기획, UI/UX) / 프론트엔드 1인 (React·TypeScript 화면 개발) / 백엔드 2인 (Django, AWS 배포), 보안 설계는 전원 공동 수행		

1 추진 배경 및 필요성 (작성비중 : 20%)

최근 개인정보 유출이나 해킹 사고가 지속적으로 발생하면서 일반 이용자들도 사고 발생 후 어떻게 대처해야 하는지 알아야 할 필요성이 커지고 있다. 실제로 2025년 SK텔레콤 개인정보 유출 사고에서는 휴대전화번호, 가입자식별번호(IMSI), 유심 인증키 등 유심과 관련된 정보가 유출되었으며, 개인정보보호위원회에서도 보이스피싱이나 스미싱 등 2차 피해에 주의할 것을 안내했다. 이처럼 개인정보 유출 사고는 단순히 정보가 외부로 노출되는 것에서 끝나는 것이 아니라, 이후 해당 정보를 악용한 추가적인 피해로 이어질 수 있기 때문에 사고 발생 직후 올바른 대처 방법을 확인하는 것이 중요하다.

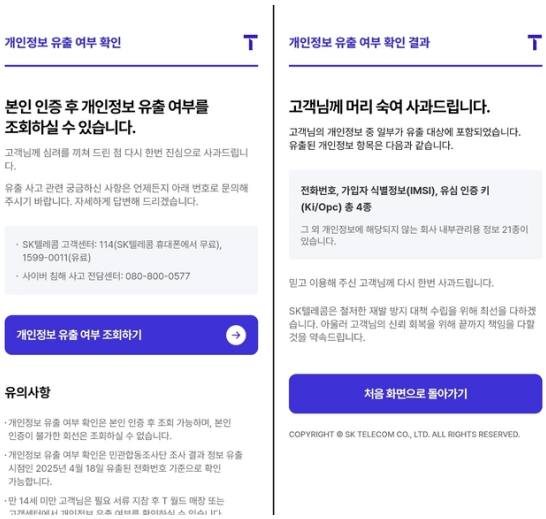
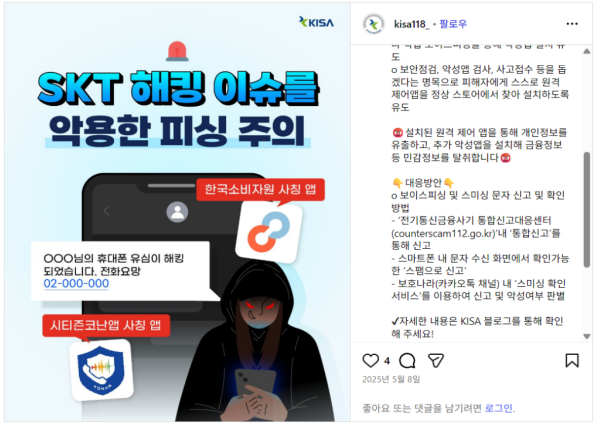
하지만 실제 사고가 발생했을 때 필요한 정보를 빠르게 찾아 대처하는 것은 생각보다 쉽지 않다. 기업의 공지사항, 정부기관의 안내, 언론 기사 등 여러 곳에서 관련 정보를 제공하고 있지만, 필요한 내용이 한곳에 정리되어 있지 않고 각각의 사이트에 나누어져 있는 경우가 많다. 또한 같은 사고를 다루더라도 기관이나 기사마다 설명하는 내용과 표현이 다르기 때문에 일반 이용자가 여러 자료를 직접 비교하면서 자신의 상황에 필요한 내용을 찾아야 하는 경우도 발생한다. 특히 보안이나 개인정보와 관련된 용어에 익숙하지 않은 이용자의 경우 안내 내용을 읽고도 자신이 어떤 조치를 먼저 해야 하는지 판단하기 어려울 수 있다.

사고 발생 초기에는 새로운 정보와 대응 방법이 계속 추가되기도 한다. 개인정보 유출 사실을 확인한 뒤에도 비밀번호를 변경해야 하는지, 별도의 서비스를 신청해야 하는

지, 추가로 확인해야 할 사항은 무엇인지 등을 사용자가 직접 찾아야 한다. 결국 빠른 대응이 필요한 상황에서도 여러 사이트와 자료를 하나씩 확인해야 하며, 이 과정에서 대응이 늦어지거나 중요한 조치를 놓칠 가능성이 있다.

이러한 불편함 때문에 많은 사람들은 공식 안내만을 확인하기보다는 포털 검색이나 유튜브, SNS 등을 통해 보다 이해하기 쉬운 대처 방법을 찾게 된다. 특히 사고 발생 직후에는 관련 정보가 짧은 시간 안에 빠르게 퍼지기 때문에, 이용자 입장에서는 어떤 내용이 공식적인 안내인지, 실제로 자신의 상황에 필요한 조치는 무엇인지 구분하기 어려울 수 있다. 여기에 출처가 명확하지 않거나 실제 사고와의 관련성이 확인되지 않은 정보까지 함께 공유되면 혼란은 더욱 커질 수 있다.

실제로 SK텔레콤 사고 당시 온라인에서는 유심 도용을 막기 위한 대응 방법으로 USIM PIN 설정을 권장하는 게시물이 빠르게 확산되었다. 그러나 보안업계에서는 해당 기능이 유심을 분실하거나 물리적으로 탈취당했을 때를 대비하는 기능으로, 통신사 서버에서 유심 정보가 유출된 사고에 대한 직접적인 대응책으로는 적절하지 않다고 설명하기도 했다. 일부 이용자는 온라인에서 공유된 방법을 따라 PIN을 설정하는 과정에서 초기 비밀번호를 잘못 입력해 유심이 잠기는 문제를 겪었으며, 관련 문의가 SK텔레콤 고객센터와 대리점에 접수되기도 했다. 또한 사고를 악용해 정부기관이나 SK텔레콤을 사칭하고 악성 앱 설치를 유도하는 피싱까지 등장하면서 한국인터넷진흥원에서도 별도의 주의 안내를 발표했다.

<table>
<tr>
<td> 
</td>
<td> 
</td>
</tr>
<tr>
<td>SKT 해킹사고 당시 안내문</td>
<td>사칭 주의 안내문</td>
</tr>
</table>

이러한 사례는 개인정보 유출 사고에서 단순히 사고 사실을 빠르게 전달하는 것뿐만 아니라, 이용자가 여러 정보 중에서 신뢰할 수 있는 내용을 구분하고 자신의 상황에 맞는 대응 방법을 확인할 수 있도록 하는 것도 중요하다는 점을 보여준다.

또한 최근에는 생성형 AI와 같은 도구의 발전으로 전문적인 지식이나 별도의 제작 기술이 없더라도 글, 이미지, 영상 등의 콘텐츠를 이전보다 쉽게 제작할 수 있는 환경이 만들어지고 있다. 정보 검색과 콘텐츠 제작이 편리해졌다는 장점이 있지만, 동시에 정확하지 않은 내용도 그만큼 빠르게 만들어지고 다시 공유될 수 있다. 특히 SNS의 카드뉴스나 짧은 영상처럼 내용을 간단하게 전달하는 콘텐츠는 중요한 조건이나 설명이 생략될 수 있으며, 출처가 불분명한 정보가 반복적으로 공유될 경우 처음에는 단순한 추측이나 의견이었던 내용도 사실처럼 받아들여질 가능성이 있다.

개인정보 유출과 같이 빠른 대응이 필요한 상황에서는 이러한 문제가 더욱 크게 나타날 수 있다. 사고 사실을 알게 된 이용자는 가능한 한 빠르게 대처 방법을 찾으려고 하기 때문에 여러 정보의 출처와 정확성을 하나하나 확인하기보다는 눈에 잘 띄고 이해하기 쉬운 정보를 먼저 따라 하게 될 수 있다. 이때 잘못된 정보를 따라 불필요한 조치를 하거나, 반대로 실제로 필요한 대응을 놓치게 되면 혼란이 커지고 추가적인 피해로 이어질 가능성도 있다.

<table>
<tr>
<td> 

관련 기사 제목 및 특정 블로그 게시글</td>
<td>- SNS에 퍼진 “대응책”으로 표시된 USIM PIN설정 기능을 무턱대고 따라했다가 문제가 생겼음을 보여주고 있다. (https://www.mt.co.kr/tech/2025/04/24/2025042411434729935)

- 실제 전문가들은, 위의 USIM PIN설정 기능이 도움이 되지 않는다고 밝혔다.

- 최근 LLM의 발전으로, 비전문가들(인플루언서 등)도 빠르게 콘텐츠를 제작하여 게시하는 경우가 많아졌다. 그러다 보니 잘못된 정보들이 섞여 퍼지는 문제가 발생하고 있다. (https://blog.naver.com/darknum/223850384373)</td>
</tr>
</table>

따라서 단순히 많은 정보를 제공하는 것보다 어떤 정보가 신뢰할 수 있는 내용인지 확인할 수 있도록 하고, 사용자의 상황에 필요한 대응 방법을 정리해 제공하는 것이 중요하다고 생각했다. 이에 개인정보 유출 등의 사고가 발생했을 때 사용자가 자신이 처한 상황을 바탕으로 질문하거나 안내에 응답하면, 정부기관이나 해당 기업 등 신뢰할 수 있는 공식 자료를 기반으로 필요한 대처 방법을 쉽고 정확하게 알려주는 서비스를 개발하고자 한다. 이를 통해 여러 곳에 흩어져 있는 정보를 사용자가 직접 찾아다니거나 여러 콘텐츠를 비교하며 판단해야 하는 부담을 줄이고, 잘못되거나 검증되지 않은 정보로 인한 혼란과 2차 피해를 줄이는 것이 우리 서비스의 목적이다.

.

AS - IS	TO - BE
- 정보 제공처 분산 - 포털 및 SNS 검색 의존 - 출처 불분명한 정보 확산 - 사고별 대처법 확인 어려움 - 유출 항목 직접 확인 - 잘못된 정보로 인한 혼란	- 공식 정보 통합 제공 - 질문 기반 맞춤형 안내 - 신뢰 가능한 출처 기반 답변 - 사고 유형별 대응 절차 제공 - 통지문 키워드 추출 - 정확한 정보 제공 및 2차 피해 예방

2 주요 기능 및 개발환경 (작성비중 : 50%)

1. 서비스 개요 및 사용자 흐름

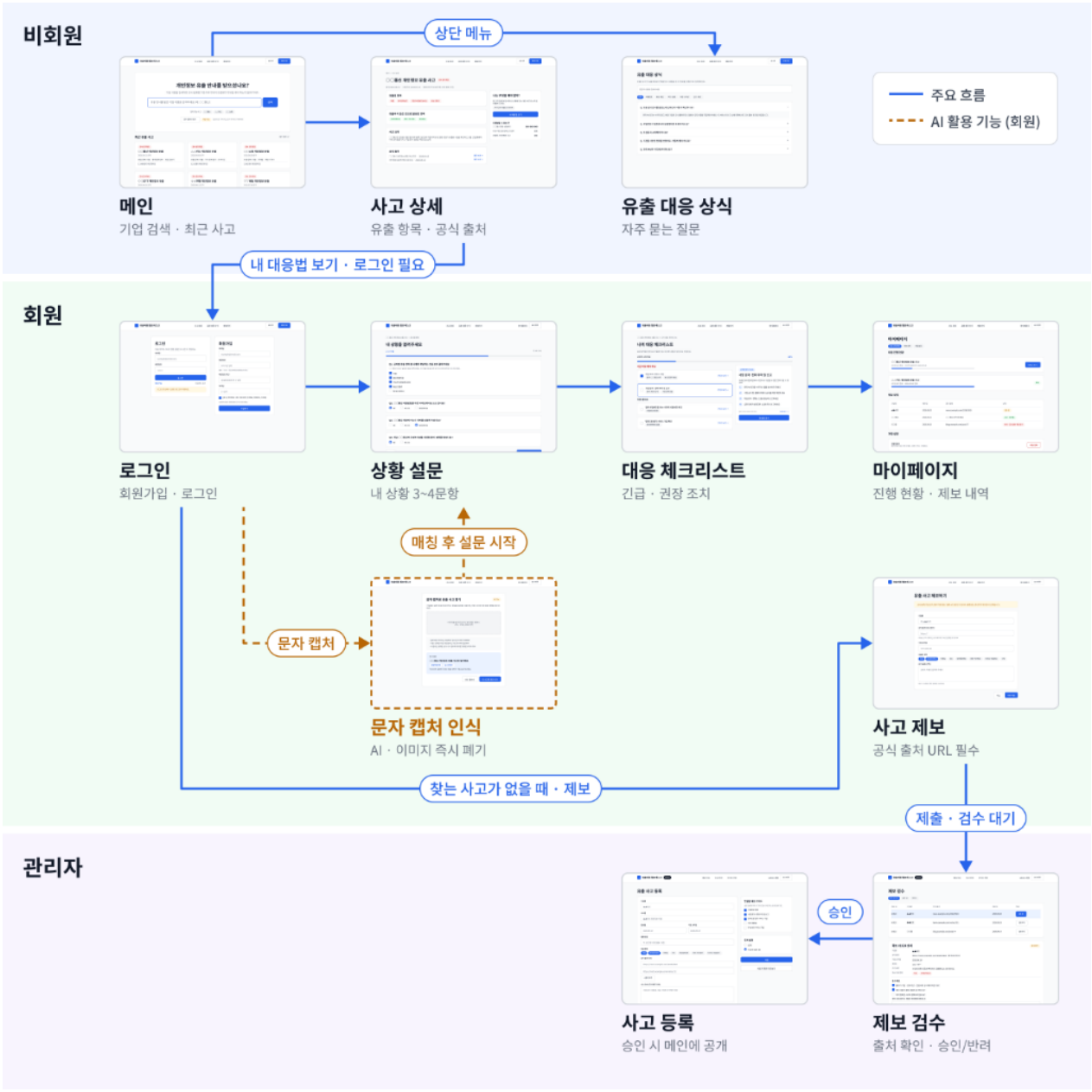
1-1. 서비스 개요

본 서비스는 개인정보 유출 사고가 발생했을 때, 사용자가 기업·정부기관의 공식 발표를 기준으로 유출 내용을 확인하고 자신의 상황에 맞는 대응 방법을 단계별로 안내받을 수 있는 웹 서비스이다. 사용자는 기업명을 검색하는 것만으로 해당 기업에서 발생한 사고의 유출 항목, 공식 출처, 신고·상담 채널을 확인할 수 있다. 회원은 유출 안내 문자를 캡처해 올려 사고를 찾을 수 있으며, 단계별 설문에 답하면 맞춤 대응 체크리스트를 제공받는다. 서비스는 아래 표의 네 가지 원칙에 따라 설계한다.

설계 원칙	세부 내용
공식 정보 기반	출처가 확인된 공식 자료만 사용, 출처 함께 표시
상황 맞춤 안내	사용자 상황에 따라 필요한 조치를 다르게 안내
쉬운 행동 안내	무엇을·어디서·어떻게 할지 단계별 제시
최소 수집·즉시 폐기	필요한 정보만 수집, 통지문 이미지 미저장

1-2. 사용자 유형별 흐름

서비스 이용자는 이용 범위에 따라 비회원, 회원, 관리자로 구분된다.



구분	이용 범위	주요 흐름
비회원	사고 조회, FAQ	검색 → 사고 상세
회원	통지문 캡처, 맞춤 대응 가이드, 제보	설문 → 체크리스트 → 진행 저장
관리자	제보 검수, 사고·가이드 관리	검수 → 사고 등록 → 공개

비회원은 로그인 없이 메인 화면에서 기업명을 검색하거나 최근 유출 사고 목록에서 해당 사고를 선택한다. 사고 상세 화면에서는 기업이 공식 발표한 유출 항목, 공식 출처, 신고·상담 채널을 확인할 수 있다. 상단 메뉴를 통해 유출 대응 상식(FAQ)도 이용할 수 있다.

회원은 사고 상세 화면에서 '내 대응법 보기'를 선택해 상황 설문으로 이동한다. 유출 안내 문자를 받은 경우에는 캡처 이미지를 올려 사고를 찾을 수 있으며, 이때 인식된 유출 항목이 설문에 미리 체크된 상태로 시작한다. 설문 응답을 바탕으로 맞춤 체크리스트가 생성되고, 조치를 완료할 때마다 진행률이 저장되어 마이페이지에서 이어서 확인할 수 있다.

찾는 사고가 등록되어 있지 않으면 회원은 공식 출처와 함께 사고를 제보할 수 있다. 관리자는 제보를 검수해 승인 시 사고를 등록하고 메인 목록에 공개하며, 반려 시 사유를 제보자의 마이페이지에 표시한다.

사고 정보 열람은 누구나 가능하도록 개방하되, 맞춤 대응 가이드와 문자 캡처 인식은 회원 기능으로 제공한다. 맞춤 대응 가이드는 설문 응답과 진행 상황을 저장해야 하기 때문이다. 문자 캡처 인식은 이미지 업로드와 외부 분석 요청이 발생하므로, 인증된 사용자로 이용을 제한해 자동화된 대량 요청과 서비스 남용을 방지한다.

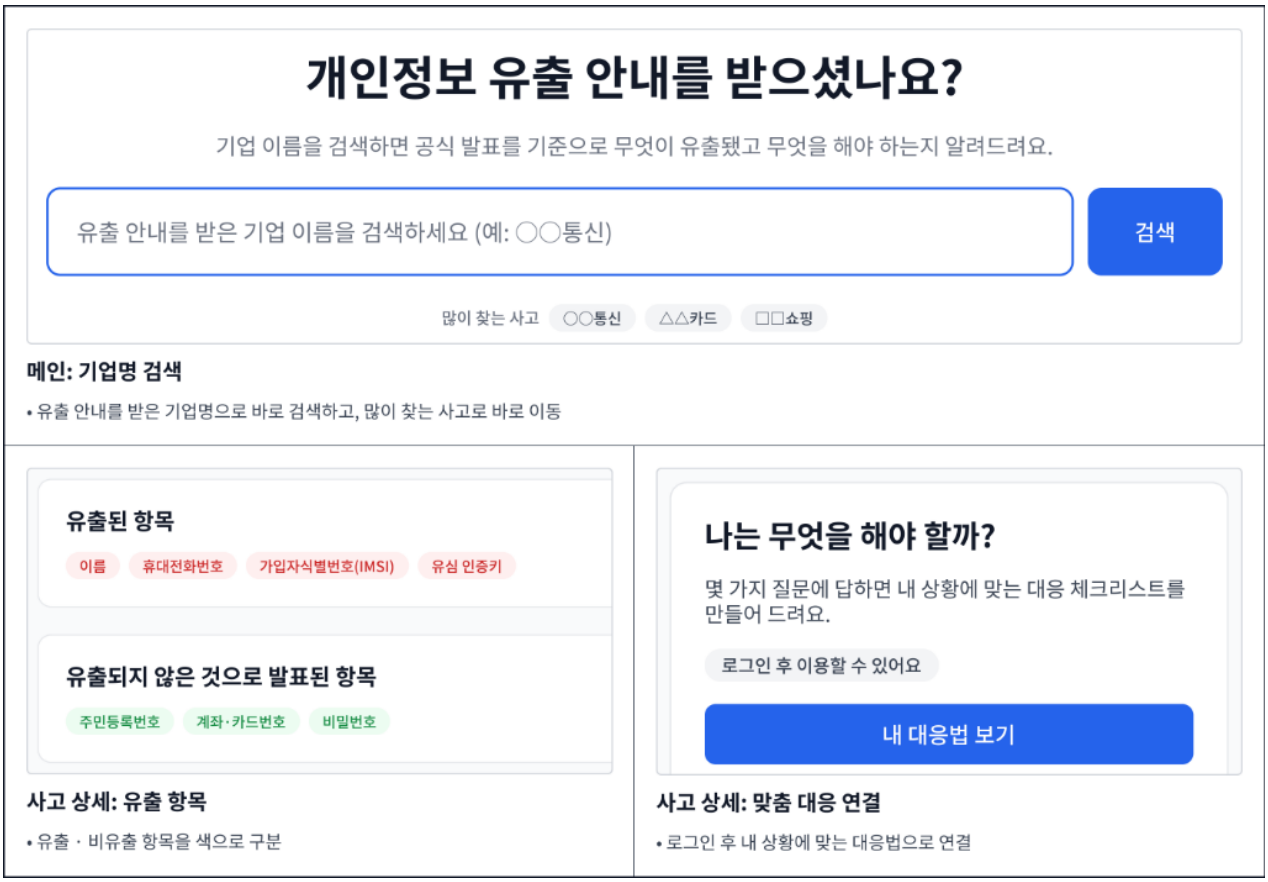
2. 상세 기능구성도 및 기능 설명

2-1. 기능 구성도



서비스 기능은 사고 조회, 맞춤 대응 가이드, 사고 제보, 마이페이지, 계정 관리, 관리자, 보안 공통의 7개 영역으로 구성된다. 보안 공통 기능은 모든 기능에 적용되며, 세부 내용은 '5. 보안 설계 및 시큐어코딩 적용 계획'에서 설명한다.

2-2. 사고 조회



메인 화면은 검색창을 중심으로 구성하여, 유출 안내를 받은 사용자가 기업명만 입력하면 바로 해당 사고를 찾을 수 있도록 한다. 최근 유출 사고 목록은 사용자 조회수 순으로 정렬해, 현재 많은 사람이 대응 중인 사고를 우선 노출한다.

사고 상세 화면은 다음 정보를 한 화면에 제공한다

- 유출된 항목과 유출되지 않은 것으로 발표된 항목 (색상으로 구분)
- 발생일, 공지일, 영향 인원 (기업 발표 기준)
- 공지 원문을 바탕으로 한 사고 요약
- 공식 출처 원문 링크
- 기업 전담 상담센터, KISA 118 등 신고·상담 채널

사용자는 출처를 직접 확인할 수 있으므로, 서비스가 제공하는 정보의 신뢰성을 스

스로 검증할 수 있다. 이 밖에 유출 사고 때 자주 혼동되는 내용을 공식 자료 기반으로 정리한 유출 대응 상식(FAQ) 페이지를 제공한다.

2-3. 맞춤 대응 가이드



맞춤 대응 가이드는 회원 전용 기능으로, 다음 순서로 진행된다.

① 문자 캡처 인식: 유출 안내 문자나 메일을 캡처해 올리면 해당 사고와 유출 항목을 찾아준다. 업로드된 이미지는 서버 메모리에서만 처리되며, 클로바 OCR로 텍스트를 추출한 뒤, 서버에서 개인정보를 마스킹하고 공식 사고 정보와 대조한다. 분석 결과는 등록된 공식 사고 정보와 대조된 경우에만 표시하며, 이미지와 원문 텍스트는 분석 직후 폐기한다.

② 상황 설문: 사용자는 3~4개 문항에 답한다. 문항은 공지된 유출 항목 중 본인에게 해당하는 항목, 비밀번호 재사용 여부, 결제수단 연결 여부, 사칭 연락 수신 여부로 구성된다.

③ 맞춤 체크리스트: 시스템은 사고의 공식 유출 항목과 설문 응답을 조합해 체크리스트를 생성하고, 각 조치를 피해의 시급성과 파급력에 따라 5단계 우선순위로 정렬한다. 금전 피해로 직결되는 조치를 가장 먼저 배치하고, 본인 인증 수단 보호, 진행 중인 공격 대응, 연쇄 피해 예방, 장기적 도용 예방 순으로 안내한다.

우선순위	기준	설문 응답	추가 조치
1	금전 피해 차단	결제수단 연결	카드 이용 내역 확인·재발급
2	인증 수단 보호	유심 정보 유출	유심 보호 서비스 가입
3	진행 중인 공격 대응	사칭 연락 수신	대응 요령 안내, 118 신고
4	연쇄 피해 예방	비밀번호 재사용	다른 사이트 비밀번호 변경
5	장기적 도용 예방	휴대전화번호 유출	명의도용 방지 서비스 확인

④ 단계별 가이드: 각 조치는 따라 하기 쉬운 단계별 설명, 공식 출처, 관련 기관 연락처와 함께 제공된다. 대응 가이드는 연락처, 계정 정보, 주민등록번호, 금융정보, 위치정보 등 유출 항목 유형별로 구성하며, 관리자가 사고별로 연결한다.

⑤ 진행률 저장: 사용자가 완료한 조치는 체크 즉시 저장되어 진행률로 표시된다. 이후 마이페이지에서 이어서 진행할 수 있다.

2-4. 사고 제보 및 관리자 검수



등록되지 않은 사고를 발견한 회원은 기업명, 공식 출처 URL, 공지일, 유출 항목을 입력해 제보할 수 있다. 공식 출처 URL을 필수 항목으로 두고 https 주소만 허용해, 출처가 불분명한 정보가 등록되는 것을 입력 단계에서부터 차단한다. 제보는 관리자 승인 전까지 공개되지 않는다.

관리자는 세 가지를 확인한 뒤 승인 또는 반려한다:

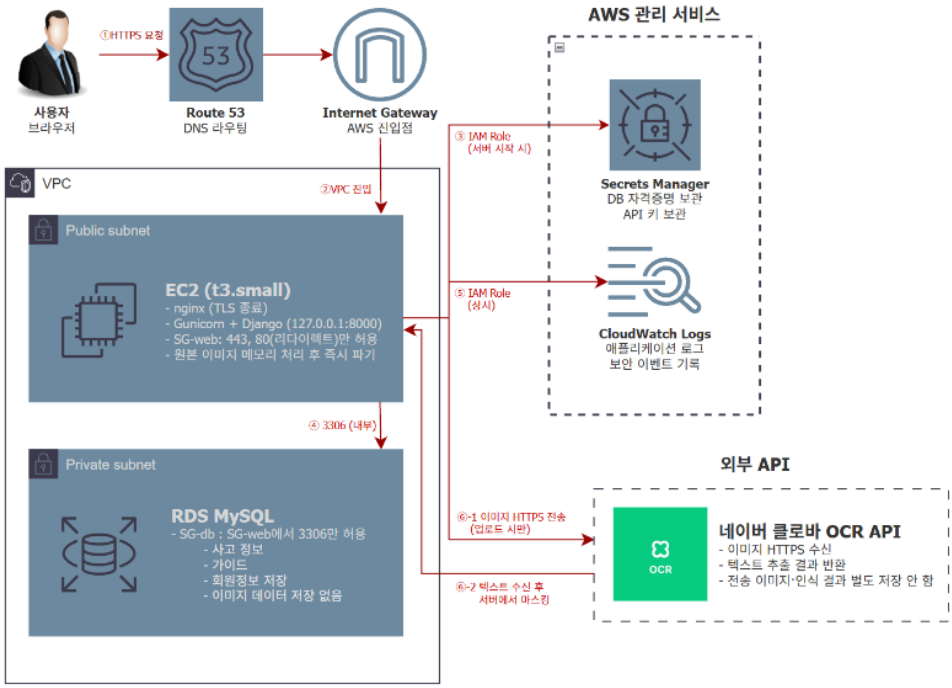
- 출처가 기업·정부기관·언론사의 공식 페이지인지
- 제보 내용이 출처와 일치하는지
- 기존 사고와 중복되지 않는지

승인된 사고는 공지 원문을 바탕으로 요약해 등록하고, 필요한 대응 가이드를 연결한다. 비공개 상태로 저장해 검토한 뒤 공개한다. 반려 시에는 사유를 입력하며, 이

사유는 제보자의 마이페이지에 표시된다.

3. 시스템 아키텍처

본 서비스는 AWS 클라우드 기반의 3-tier 아키텍처로 구성되며, VPC 내 Public/Private Subnet을 분리하여 보안 경계를 명확히 설계하였다.



① 사용자 → Route 53

사용자가 브라우저에서 서비스 도메인에 HTTPS로 접속하면 Route 53이 DNS 조회를 처리해 요청을 AWS로 라우팅한다.

② Route 53 → Internet Gateway → EC2

Internet Gateway를 통해 VPC로 진입한 요청은 Public Subnet의 EC2 인스턴스에 도달한다. nginx가 TLS를 종료하고 리버스 프록시로서 내부 포트 8000의 Gunicorn+Django 애플리케이션으로 전달한다.

③ EC2 → Secrets Manager
서버 시작 시 EC2에 부여된 IAM Role을 통해 Secrets Manager에서 DB 자격증명과 클로바 OCR API 키를 런타임에 조회한다. 자격증명은 코드 및 환경변수에 평문으로 저장하지 않는다.

④ EC2 → RDS MySQL
사용자 요청 처리 시 EC2가 Private Subnet의 RDS MySQL에 접근해 사고 정보, 가이드, 회원 정보를 조회하거나 저장한다. 포트 3306은 SG-web에서 오는 트래픽만 허용하며 인터넷에서 직접 접근은 불가능하다.

⑤ EC2 → CloudWatch Logs
애플리케이션 로그와 보안 이벤트를 IAM Role 기반으로 CloudWatch Logs에 상시 전송한다. 보안 사고 발생 시 로그 추적이 가능하다.

⑥ EC2 ↔ 클로바 OCR API
회원이 통지문 이미지를 업로드할 때에만 호출된다. 통지문 이미지를 HTTPS로 전송해 텍스트를 추출하고, 수신한 텍스트에서 이름·전화번호 등을 마스킹한 뒤 매칭에 사용한다. 원본 이미지는 메모리에서 즉시 파기하고 DB에 저장하지 않는다.

3-1. 네트워크 보안 설계
EC2 보안그룹(SG-web)은 443(및 리다이렉트용 80)만 허용하고, Gunicorn은 127.0.0.1:8000에 바인드해 외부에서 접근할 수 없다. SG-db는 SG-web에서 오는 3306만 허용한다
WAF, ALB, Multi-AZ는 현재 MVP 범위에서 제외하였으며, 향후 트래픽 증가 및 서비스 확장 시 도입을 계획한다.

4. 개발 환경
4-1. 개발 환경 요약

구분	기술
언어	Python, TypeScript
FE	React, Vite
BE	Django, Gunicorn
DB	MySQL (AWS RDS)
웹 서버	nginx
인프라	AWS EC2, RDS, Route 53, Secrets Manager, CloudWatch Logs
외부 API	네이버 클로바 OCR API
협업 툴	GitHub, Figma, Notion
보안 점검 툴	Bandit, Semgrep, pip-audit, npm audit

4-2. 프론트엔드
프론트엔드는 React와 TypeScript 기반의 SPA(Single Page Application)로 구성한다. React는 상황 설문, 체크리스트처럼 반복되는 화면 요소를 컴포넌트 단위로 재사

용할 수 있어 개발 효율과 유지보수성이 높다. TypeScript는 정적 타입 검사를 통해 API 응답과 폼 데이터의 구조 오류를 개발 단계에서 차단할 수 있어 채택하였다.

빌드 도구로는 Vite를 사용한다. Vite는 빌드 속도가 빠르고, 개발 중에도 프록시 설정으로 /api 요청을 백엔드에 전달할 수 있어 운영 환경과 동일한 같은 도메인 구조를 재현할 수 있다. 빌드된 정적 파일은 EC2의 nginx가 서빙하며, API 요청은 같은 도메인의 /api 경로를 통해 Django로 전달된다. 프론트엔드와 백엔드가 하나의 도메인을 공유하므로 별도의 CORS 설정 없이 세션 기반 인증을 적용할 수 있다.

화면 이동은 React Router로 비회원·회원·관리자 화면을 분리해 관리한다. 로그인 상태와 설문 응답 같은 전역 상태는 가벼운 상태 관리 라이브러리인 Zustand로 처리하고, 스타일은 styled-components를 사용해 컴포넌트 단위로 관리한다. 서버와의 통신에는 Axios를 사용하며, 요청 설정을 통해 변경 요청에 CSRF 토큰 헤더가 자동으로 첨부되도록 구성한다.

또한 시맨틱 HTML, ARIA 속성, 키보드 탐색을 지원해 고령층과 시각장애인 등 디지털 취약계층도 서비스를 이용할 수 있도록 한다.

4-3. 백엔드 및 인프라

백엔드는 Python 기반의 Django로 구현한다. Django는 ORM, 세션 인증, CSRF 방어, 비밀번호 해시 저장 등 웹 서비스에 필요한 보안 기능을 프레임워크 차원에서 기본 제공한다. 보안 기능을 직접 구현할 때 생길 수 있는 오류를 줄일 수 있어 채택하였다. 특히 ORM을 통해 모든 데이터베이스 질의를 매개변수화된 쿼리로 처리하므로 SQL 인젝션을 구조적으로 방지할 수 있다. API는 Django REST Framework로 구성하며, 애플리케이션은 WSGI 서버인 Gunicorn으로 구동한다.

데이터베이스는 AWS RDS 기반의 MySQL을 사용한다. 관리형 서비스로 백업과 패치가 자동화되어 있으며, Private Subnet에 배치해 인터넷에서 직접 접근할 수 없도록 한다. 서버, 네트워크, 자격증명 관리 등 인프라 구성의 세부 내용은 '3. 시스템 아키텍처'에서 설명한다.

4-4. 외부 API

통지문 인식에는 네이버 클로바 OCR API를 사용한다. 한글 인식 정확도가 높고 별도의 모델 학습 없이 API 호출만으로 이미지 속 텍스트를 추출할 수 있어, 제한된 개발 기간 안에 안정적으로 기능을 구현할 수 있다.

4-5. 협업 및 보안 점검 도구

협업은 GitHub로 코드 버전과 이슈를 관리한다. main 브랜치에는 직접 반영하지 않고 Pull Request와 코드 리뷰를 거쳐 병합한다. 화면 설계는 Figma로, 회의록과 일정은 Notion으로 공유한다.

보안 점검은 개발 단계부터 자동화 도구로 수행한다. 정적 분석으로는 Bandit(Python)과 Semgrep(Python·TypeScript)으로 코드의 보안약점을 점검한다. 또한, 의존성 점검으로 pip-audit와 npm audit, GitHub Dependabot으로 취약점이 알려진 외부 라이브러리를 탐지한다. 마지막으로 배포 전 점검은 Django의 check --deploy 명령으로 보안 관련 설정 누락을 확인한다. 이후, 점검 결과는 행정안전부 SW 보안약점 기준에 맞춰 분류하고, 개발 기간 중 매주 점검한다.

5. 보안 설계 및 시큐어코딩 적용 계획

5-1. 보안 설계 원칙

본 서비스는 행정안전부 SW 개발보안 가이드의 보안약점 기준을 기본으로 하고, OWASP Top 10:2025와 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드(2026)를 보조 기준으로 삼아 설계 단계부터 보안을 반영한다. 설계 전반에는 다음 네 가지 원칙을 적용한다.

첫째, 최소 수집이다. 회원가입 시 이메일, 비밀번호, 닉네임만 수집하며, 서비스의 핵심 입력인 통지문 이미지는 저장하지 않고 분석 직후 파기한다.

둘째, 최소 권한이다. 비회원, 회원, 관리자에게 각자 필요한 기능만 허용한다. 서버와 데이터베이스 계정에도 업무에 필요한 최소한의 권한만 부여한다.

셋째, 다계층 방어다. 하나의 보안 장치가 무력화되더라도 다른 계층에서 공격을 차단할 수 있도록 네트워크, 애플리케이션, 데이터의 세 계층에 각각 보호 조치를 둔다. 네트워크 계층의 구성은 '3. 시스템 아키텍처'에서 설명하였다.

넷째, 검증된 기능 우선이다. 인증, 세션, CSRF 방어, 비밀번호 해시처럼 보안에 직결되는 기능은 직접 구현하지 않고 Django가 제공하는 검증된 기능을 우선 사용한다. 직접 구현으로 인한 보안약점 발생 가능성을 줄이기 위함이다.

인증 방식으로는 토큰 기반의 JWT 대신 서버 세션 방식을 채택하였다. JWT는 토큰을 브라우저 스크립트가 직접 다뤄야 하므로 XSS 발생 시 탈취 위험이 있고, 로그아웃 후에도 만료 전까지 토큰이 유효해 즉시 무효화하기 어렵다. 반면 세션 방식은 세션 식별자를 HttpOnly 쿠키로 전달해 스크립트 접근을 차단할 수 있고, 서버에서 세션을 삭제하는 즉시 인증이 무효화된다. 또한 프론트엔드와 백엔드가 같은 도메인을 사용하므로 Django의 기본 CSRF 방어를 그대로 적용할 수 있다.

권한 설계는 역할 기반 접근 제어와 객체 단위 검증을 함께 적용한다. 요청마다 사용자의 역할이 해당 기능에 접근할 수 있는지를 서버에서 먼저 확인한다. 이어서 요청한 데이터가 실제로 그 사용자의 소유인지를 다시 확인한다. 이를 통해 URL의 식별자를 바꿔 다른 사용자의 체크리스트나 제보 내역을 조회하는 공격(IDOR)을 차단한다.

5-2. 위협 분석 및 보안약점 대응

본 서비스에서 발생할 수 있는 보안 위협을 행정안전부 소프트웨어 보안약점 진단 가이드(2021), OWASP Top 10:2025, 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드(2026)를 기준으로 분석하고, 각 영역별 대응 방안을 다음과 같이 수립하였다.

영역	관련 기준	주요 대응 내용 및 구현 방식
가. 인프라 보안	SR2-5 암호키 관리 · SR2-6 암호연산 · A02	VPC Public/Private Subnet 분리로 DB 격리, 보안그룹 참조로 DB 접근을 EC2로 한정, IAM Role 기반 인증으로 API 키 하드코딩 제거, Secrets Manager로 자격증명·API 키 런타임 조회, DEBUG=False 및 보안 헤더 설정
나. 통신 구간 보안	SR2-7 중요정보 저장 · SR2-8 중요정보 전송 · A04 · SN · WEB-20	nginx에서 TLS 종료 및 HTTPS 강제, HTTP→HTTPS 리다이렉션, HSTS 헤더 적용, 비밀번호 단방향 해시(PBKDF2) 저장
다. 인증 · 세션	SR2-1 인증 대상 및 방식 · SR2-2 인증 수행 제한 · SR2-3 비밀번호 관리 · SR4-1 세션통제 · A07 · BF · IA · IS · AU	비밀번호 최소 8자·영문+숫자+특수문자 조합 정책, 로그인 5회 실패 시 계정 잠금(django-axes), 세션 만료 시간 설정, 로그인 성공 시 세션 ID 재발급, 쿠키 HttpOnly·Secure·SameSite 속성 설정
라. 인가 · 접근 제어	SR2-4 중요자원 접근통제 · SR1-9 보안기능 입력값 검증 · A01 · IN · AE	역할 기반 접근 제어(비회원/회원/관리자) Django 데코레이터로 구현, 서버사이드 권한 체크로 IDOR 방지, 관리자 페이지 경로 비공개 및 접근 IP 제한
마. 입력값 검증 · 인젝션 방지	SR1-1 DBMS 조회 및 결과 검증 · SR1-4 시스템 자원 접근 · SR1-5 웹 서비스 요청 및 결과 검증 · SR1-6 웹 기반 중요 기능 수행 요청 유효성 검증 · A05 · CI · SI · XS · CF	Django ORM 사용으로 SQL 삽입 방지(raw SQL 미사용), 입력값 서버사이드 화이트리스트 검증, React의 JSX 자동 이스케이프, dangerouslySetInnerHTML 사용 금지, CSP 헤더 적용으로 XSS 방지, CSRF 미들웨어 적용
바. 에러 처리 · 로깅	SR3-1 예외처리 · A09 · A10 · EP · IL	커스텀 에러 페이지로 스택 트레이스 미노출, 예외 발생 시 안전한 기본값 반환, CloudWatch로 보안 이벤트 상시 전송(로그인 실패·권한 위반 등), 로그 내 개인정보 마스킹

보안 위협 요약 및 대응 표

5-2-1. 인프라 보안

DB를 Private Subnet에 배치하여 인터넷에서 직접 접근이 구조적으로 불가능하도록 설계하였다. 보안그룹은 SG-web(443·80 허용)과 SG-db(SG-web에서 3306만 허용)로 구성하며, IP가 아닌 보안그룹 참조 방식을 적용해 설정 변경 시에도 정책이 유지된다. Gunicorn은 127.0.0.1에만 바인드한다. AWS 서비스 접근은 EC2 인스턴스에 부여된 IAM Role로 처리하여 API 키를 코드나 환경변수에 저장하지 않으며(SR2-5 암호키 관리·행안부 보안기능 "하드코드된 중요정보" 대응), DB 자격증명과 클로바 OCR API 키는 Secrets Manager에서 서버 시작 시 런타임으로 조회한다.

5-2-2. 파일 처리·외부 API 연동

통지문 이미지는 서비스 내에서 가장 민감한 데이터에 해당한다. 업로드 시 확장자·파일 크기뿐 아니라 파일 시그니처(매직 바이트)를 검증하여 위험한 형식의 파일 업로드를 차단한다(SR1-10 업로드·다운로드 파일 검증). 검증을 통과한 이미지는 S3 등 영구 저장소에 저장하지 않고 서버 메모리에서만 처리하며, 클로바 OCR API에 원본 이미지를 HTTPS로 전송하여 텍스트를 추출한다. 추출된 텍스트에서 이름·전화번호 등 민감정보를 마스킹 처리한 뒤 유출 항목 매칭에 활용하고, 원본 이미지는 즉시 파기한다. 클로바 OCR 공식 약관에 따르면 전송된 이미지를 별도로 저장하거나 활용하지 않으며, 통신 구간은 HTTPS로 암호화된다.

5-2-3. 관리자 승인 워크플로우

사고 제보와 가이드 문구는 모두 관리자 승인 전까지 비공개 상태를 유지한다. 승인 전 콘텐츠는 URL을 직접 입력하더라도 접근할 수 없도록 서버사이드에서 상태값(대기/승인/반려)을 검증한다(SR2-4 중요자원 접근통제). 검토 기준은 콘텐츠 타입에 따라 분리하여, 사고 제보는 출처 일치 여부 및 중복 확인을 기준으로, 가이드 문구는 조치 내용의 적절성 및 안전성을 기준으로 검수한다.

5-3. 개인정보 처리 보안

본 서비스는 개인정보 유출 피해자를 돕는 서비스인 만큼, 서비스 자체가 새로운 유출 경로가 되지 않도록 개인정보의 수집부터 파기까지 전 단계에 보호 조치를 적용한다.

단계	회원정보	통지문 이미지·텍스트
수집	이메일, 비밀번호, 닉네임만 수집	수집하지 않음
이용	로그인, 대응 진행 현황 저장	사고, 유출 항목 매칭
보관	비밀번호 단방향 해시, DB는 Private Subnet에 격리	저장하지 않음
파기	탈퇴 시 즉시 삭제	분석 직후 즉시 파기

회원정보는 서비스 제공에 필요한 최소 항목만 수집하며, 비밀번호는 복호화할 수 없는 해시 값으로만 저장한다. 탈퇴 시에는 회원정보와 함께 대응 진행 기록, 제보 내역을 즉시 삭제한다. 단, 관리자 검수를 거쳐 등록된 사고 정보는 기업이 공식 발표한 공개 정보이므로 유지하되, 제보자와의 연결 정보만 삭제한다.

통지문 이미지는 이름, 전화번호 등 민감한 정보가 포함될 수 있어 서비스에서 가장 엄격하게 다룬다. 이미지는 디스크나 데이터베이스에 저장하지 않고 서버 메모리에서만 처리한다. 추출된 텍스트는 민감정보를 마스킹한 뒤 매칭에만 사용하며, 처리가 끝나면 이미지와 원문 텍스트를 즉시 파기한다.

서비스 운영 로그에도 개인정보가 남지 않도록, 로그 기록 시 이메일과 전화번호 등은 마스킹하여 저장한다.

또한, 통지문의 텍스트 추출은 네이버 클라우드의 CLOVA OCR에 처리를 위탁한다. 이미지는 HTTPS로 암호화하여 전송한다. CLOVA OCR 사용 가이드에 따르면 전송된 이미지와 인식 결과는 별도로 저장·활용되지 않는다. 이 위탁 사실은 개인정보 처리방침과 이미지 업로드 화면에 함께 고지하여, 이용자가 업로드 전에 외부 처리 여부를 확인할 수 있도록 한다.

마지막으로, 서비스 내 상시 접근 가능한 위치에 개인정보 처리방침을 게시하고, 다음 내용을 명시한다. 또한, 이용자는 마이페이지에서 자신의 정보를 확인하고 언제든 탈퇴를 통해 삭제를 요청할 수 있다.

- 수집 항목과 목적
- 보유 기간과 파기 절차
- 처리 위탁 현황
- 이용자의 열람 · 정정 · 삭제 요청 방법

5-4. 보안 점검 및 검증 계획

보안 점검은 개발 완료 후 일괄 수행하는 방식이 아닌, 개발 전 과정에 걸쳐 지속적으로 수행한다.

개발 단계에서는 '4-5. 협업 및 보안 점검 도구'의 정적 분석 도구와 의존성 점검 도구를 코드 병합 전에 실행하며, 식별된 보안약점은 병합 이전에 조치한다. 외부 라이브러리의 신규 취약점은 Dependabot 알림을 통해 파악하고, 영향이 확인된 경우 즉시 버전을 갱신한다.

자동화 도구로 탐지하기 어려운 로직 수준의 취약점은 기능 단위 테스트로 검증한다. 타 사용자 리소스에 대한 비인가 접근, 반복 로그인 시도에 대한 차단, 미승인 콘텐츠의 외부 노출 여부 등 '5-2. 위협 분석 및 보안약점 대응'에서 정의한 검증 항목을 각 기능 구현 시점에 확인한다.

완료 단계에서는 행정안전부 SW 보안약점 기준에 따라 전체 소스코드를 재점검하고, 배포 전 Django의 check --deploy 명령으로 보안 설정의 누락 여부를 확인한다.
점검 과정에서 발견된 보안약점은 GitHub 이슈로 관리하여 팀 내 조치 현황을 공유

하고, 위험도에 따라 우선순위를 정해 조치한다. 조치 이후에는 동일한 방법으로 재검증하여 보안약점의 해소 여부를 확인한다.

5-5. 개발 일정

기간	주요 작업	담당
1주차 (10.6~10.9)	AWS 인프라·DB 설계, 개발 환경 구축, 회원가입·로그인	BE, FE
2주차 (10.12~10.16)	사고 조회·상세, 관리자 사고 등록, 설문·체크리스트	전원
3주차 (10.19~10.23)	문자 캡처 인식(OCR 연동·마스킹), 제보·검수, 마이페이지	전원
4주차 (10.26~10.30)	보안약점 전수 점검 및 조치, 통합 테스트, 배포, 대회 미션 대응	전원

3 활용방안 및 기대효과 (작성비중 : 30%)

1. 활용 방안

1-1. 공식 출처 기반 유출사고 확인 및 대응 지원

개인정보 유출 사고가 발생하면 기업은 통지문을 발송하지만, 통지문만으로는 어떤 정보가 유출되었고 본인이 무엇을 해야 하는지 바로 파악하기 어렵다. 본 서비스에서는 사용자가 기업명을 검색하거나 받은 유출 안내 문자를 캡처해 올리면 해당 사고를 찾아, 기업이 공식 발표한 유출 항목과 유출되지 않은 항목을 구분하여 보여준다. 공식 출처 원문과 신고·상담 채널도 함께 제공하기 때문에 사용자는 여러 곳을 찾아다니지 않고도 사고 내용을 정확하게 확인할 수 있다.

사고 내용을 확인한 뒤에는 대응 단계로 이어진다. 사용자가 몇 가지 상황 설문에 답하면, 서비스는 사고의 공식 유출 항목과 설문 응답을 조합해 맞춤형 대응 체크리스트를 만든다. 대응 가이드는 이름·연락처, ID·비밀번호, 주민등록번호, 금융정보, 위치정보의 5대 유출 유형을 기준으로 구성되어 있으며, 조치를 피해의 시급성에 따라 1~5순위로 정렬해 안내한다. 이를 통해 사용자는 유출 사실을 확인하는 데서 그치지 않고 스스로 필요한 조치를 마무리할 수 있으며, 스미싱이나 계정 도용과 같은 2차 피해를 예방할 수 있다.

1-2. 피해자 대응 단계별 유관기관 연계

유출 통지를 받은 사람이 실제로 대응하려면 조치마다 연락해야 할 곳이 다르다. 사칭 문자를 받았다면 KISA 118 상담센터에, 결제수단이 연결되어 있다면 카드사에, 계정 정보가 유출되었다면 해당 기업의 고객센터에 연락해야 한다. 하지만 피해자는 대부분 이런 구분을 알지 못한 채 여러 기관을 직접 찾아봐야 하고, 그 사이에 대응이 늦어지기 쉽다. 본 서비스는 대응 체크리스트의 각 조치에 해당 조치를 도와줄 수 있는 기관의 연락처와 이용 방법을 함께 안내한다. 피해자는 체크리스트를 따라가면서 지금 해야 할 일과 연락할 곳을 함께 확인할 수 있으므로, 기관을 찾는 과정 없이 바로 필요한 도움을 받을 수 있다. 이처럼 본 서비스는 피해자의 대응 과정 안에서 흩어져 있는 유관기관의 상담 창구를 이어주는 역할을 한다.

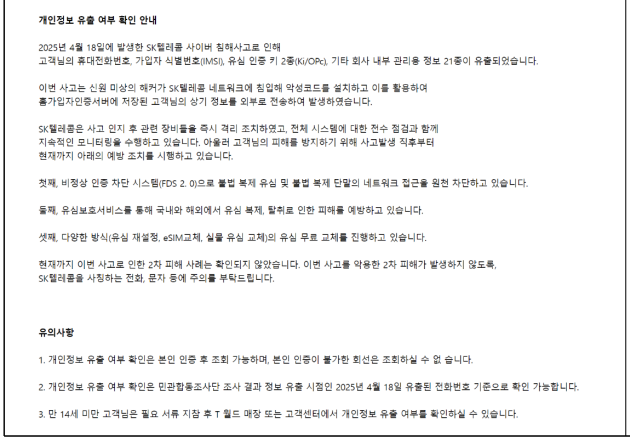
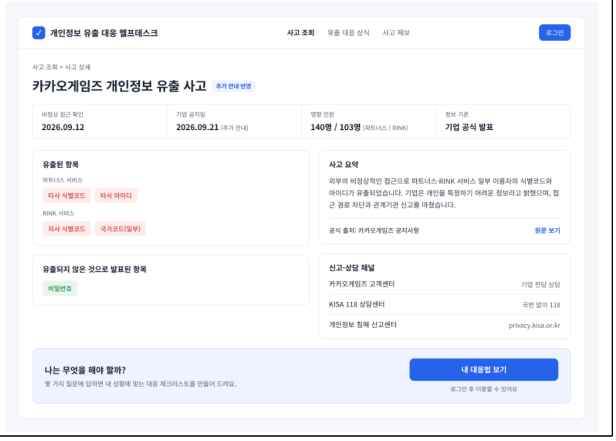
2. 기대효과

2-1. 정성적 효과

본 서비스는 기업과 정부기관의 공식 발표만을 근거로 정보를 제공하기 때문에, 사용자는 출처가 불분명한 온라인 정보에 기대지 않고도 본인 상황에 맞는 대응 방법을 정확하고 빠르게 확인할 수 있다. 사고 상세 화면과 대응 가이드에는 공식 출처 원문이 함께 표시되므로 사용자가 정보의 신뢰성을 직접 검증할 수도 있다. 이를 통해 SNS 등에서 퍼지는 검증되지 않은 대응법을 따르다 생기는 혼란을 줄이고, 잘못된 정보로 인한 2차 피해를 예방할 수 있다.

이러한 효과는 선행연구와도 맞닿아 있다. 김기윤(2019)의 「기업의 보안수준과 개인정보 유출 통지 활동이 개인정보 유출사고 대응 행동에 미치는 영향」에 따르면, 개인정보 유출 사고가 발생하더라도 고객이 기업의 유출 통지 활동을 정당하다고 인지하면 인지적·감성적 반응이 완화되고, 이후 구전 의도, 전환 의도, 단체소송 의도도 감소하는 것으로 나타났다. 이는 사고 그 자체만큼이나 사고 이후 고객에게 정보가 어떻게 전달되고 받아들여지는지가 고객의 대응 행동에 영향을 준다는 점을 보여준다. 본 서비스는 기업을 대신해 통지를 수행하지는 않지만, 5대 유출 유형별 맞춤 체크리스트와 이해하기 쉬운 공식 정보 제공을 통해 통지 내용을 고객이 정확히 이해하고 실제 행동으로 옮기도록 돕는다. 이는 고객이 기업의 유출 통지를 신뢰할 수 있는 대응으로 받아들이는 데 기여하고, 나아가 고객의 부정적 대응 행동을 완화하며 기업과 고객 간 신뢰 관계를 유지하는 데에도 긍정적인 영향을 줄 것으로 기대된다.

기존의 공공 서비스와 비교했을 때도 역할이 분명하다. 개인정보보호위원회와 KISA가 운영하는 '털린 내 정보 찾기' 서비스는 불법 유통된 계정 정보 가운데 본인의 계정이 포함되어 있는지를 확인하는 데 초점이 맞춰져 있다. 본 서비스는 여기서 한 단계 더 나아가, 특정 유출 사고를 기준으로 무엇이 유출되었는지 확인하고 그에 맞는 조치를 끝까지 이어갈 수 있도록 돕는다. 5대 유출 유형별 맞춤 체크리스트를 1~5순위로 정렬해 제공하고, 완료한 조치는 진행률로 저장되어 마이페이지에서 이어서 확인할 수 있다. 따라서 사용자는 유출 사실을 확인한 뒤에도 무엇을 해야 할지 몰라 멈추지 않고, 초동 조치를 스스로 마무리할 수 있다.

기존 개인정보 유출 통지서	개발 시스템 예시
	

2-2. 정량적 효과

본 서비스는 유출 통지를 받은 사용자가 초동 조치를 마치기까지 걸리는 시간을 줄이는 것을 목표로 한다. 기존에는 기업 공지, 정부기관 안내, 언론 기사를 각각 찾아보고 본인에게 필요한 조치를 직접 판단해야 했지만, 본 서비스에서는 기업명 검색

과 단계별 문항의 설문만으로 해야 할 조치가 정리된다. 카드 이용 내역 확인이나 유심 보호 서비스 가입처럼 시급한 조치를 우선순위에 배치되므로, 사용자는 가장 중요한 조치부터 빠르게 마칠 수 있고 피해가 번질 가능성도 그만큼 줄어든다. 이러한 효과는 체크리스트 진행률 데이터를 통해 긴급한 우선순위 완료율과 조치 완료까지 걸린 시간으로 측정할 수 있다.

유관기관의 상담 부담도 줄일 수 있다. 대형 유출 사고가 발생하면 "내 정보도 유출되었는지", "무엇을 해야 하는지"와 같은 기본적인 문의가 기업과 기관의 콜센터로 한꺼번에 몰린다. 본 서비스는 이런 내용을 공식 자료를 바탕으로 먼저 안내하기 때문에, 사용자는 단순한 확인을 위해 상담 대기를 하지 않아도 된다. 그 결과 유관기관에는 실제 신고나 전문 상담이 필요한 문의가 중심으로 전달되어, 상담 인력을 보다 효율적으로 운영할 수 있다.

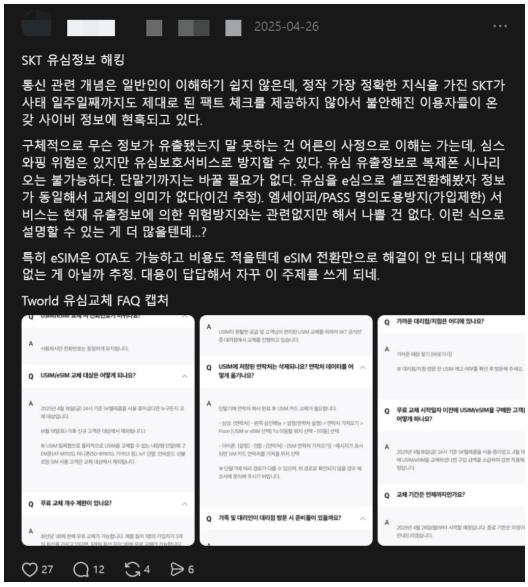
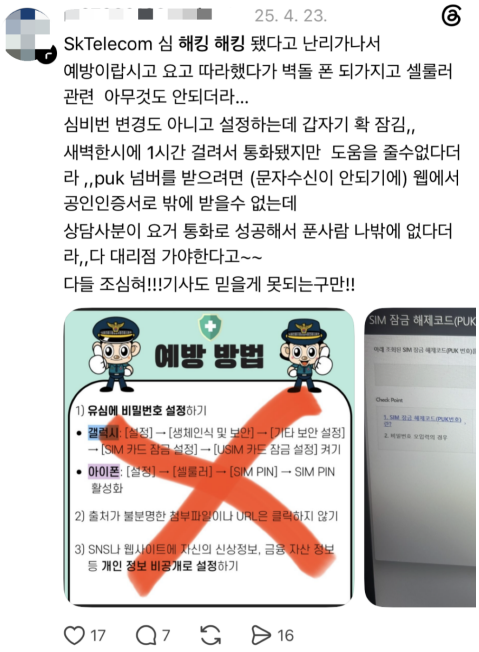
3. 실제 사례 기반 효과 분석

선정 사례 : SKT 유심 해킹 사건 (2025)

사고 타임라인 :

날짜	대응 사항 및 내용
2025.4.18 - 18:09	사내 데이터 이상 움직임 발견
2025.4.18 - 23:20	악성코드 및 해킹 공격 사실 확인
2025.4.19 - 01:49	관련 분석 시작
2025.4.19 - 13:40	고객 유심 정보 유출 정황 발견
2025.4.20 - 16:46	KISA 신고
2025.4.22 - 10:00	개인정보보호위원회에 신고
2025.4.27 - 15:00	기업 및 금융권 SKT 유심교체 독려
2025.4.28 - 10:30	전국 T월드 유심교체 무료 선언
2025.4.28 - 13:50	카드사 및 캐피탈 SKT 사용자 인증 중단

3-1. 주요 혼란 지점

<table>
<tr>
<td> 
</td>
<td> 
</td>
</tr>
<tr>
<td>가독성이 떨어지는 정보</td>
<td>잘못된 정보로 피해를 호소</td>
</tr>
</table>

왼쪽에 위치한 사진은 SKT에서 제공한 공식 자료를 한 SNS 사용자가 가져와 게시한 글이다. 공식 자료라는 점에서 의의는 있으나, 사람들의 눈에 잘 안 들어온다는 단점이 있다. 오른쪽 사진은 SNS상에서 돌아다니는 게시글로 조치를 취했으나, 오히려 피해를 봤음을 설명하며 정보를 그대로 따르지 말라는 의견을 제시하고 있는 글이다. 이런 이유들로 사람들은 대처 방법을 찾고 결정하는데 있어 큰 혼란을 겪는다.

3-2. 기대 개선 효과

서비스 대응	기대 개선 효과
통지문 캡처 OCR 유출 항목 자동 인식	사용자 개별 유출 항목에 맞는 가이드를 즉시 제공받아 불필요한 조치 없이 본인 상황에 집중 가능
단계별 체크리스트 제공	가장 시급한 조치부터 순서대로 수행할 수 있어 초기 대응 지연 및 누락 방지
"관리자 승인 + 출처 표시(기업·정부기관·언론)"	검증된 정보만 노출되어 사칭·피싱 등 2차 피해 가능성 감소
진행률 저장 + 관리자 특수 조치 추가	사고 종료 시까지 미완료 조치를 추적할 수 있어 장기적 피해 예방 가능

4. 향후 발전 방안

현재 서비스는 공식 정보에 기반한 사고 확인과 맞춤 대응 안내라는 핵심 기능에 집중하여 설계하였으며, 이후에는 다음과 같은 방향으로 서비스를 확장할 수 있다.

먼저 LLM 기반의 대화형 인터페이스를 도입하여 맞춤 안내를 고도화할 수 있다. 지금은 정해진 3~4개 문항의 설문으로 사용자의 상황을 파악하지만, 대화형 인터페이스를 적용하면 사용자가 "어제 택배 문자를 받고 링크를 눌렀다"처럼 자신의 상황을 자연스럽게 설명하는 것만으로 알맞은 대응 체크리스트를 받을 수 있다. 이때도

답변은 서비스에 등록된 공식 사고 정보와 대응 가이드 안에서만 생성하도록 제한하여, 본 서비스의 '공식 정보 기반' 원칙을 그대로 유지한다.

다음으로 알림 기능을 추가할 수 있다. 유출 사고는 처음 공지 이후 추가 유출 사실이 확인되는 경우가 많고, 카드 재발급처럼 시간이 지나서 확인해야 하는 조치도 있다. 사용자가 동의한 경우에 한해 마이페이지에 등록된 사고의 추가 공지가 올라오거나 후속 조치 시점이 되었을 때 알림을 보내면, 사용자가 대응을 중간에 놓치지 않고 끝까지 이어갈 수 있다.

사고 등록 과정의 자동화도 필요하다. 현재는 관리자가 제보를 검수해 사고를 등록하는 방식이어서 새로운 사고가 서비스에 반영되기까지 시간이 걸린다. 개인정보보호위원회와 KISA 등 유관기관의 공식 발표와 기업 공지를 자동으로 수집하고, 관리자는 최종 확인만 하는 방식으로 개선하면 사고 반영 속도와 정보의 최신성을 함께 높일 수 있다.

마지막으로 다국어 지원을 확대할 수 있다. 현재 서비스는 한국어를 중심으로 제작되었지만, 국내 서비스를 이용하는 외국인 근로자와 유학생도 유출 사고의 피해자가 될 수 있다. 주요 언어로 대응 가이드와 화면을 제공하면 언어 때문에 대응 방법을 이해하지 못하는 사용자 없이, 국내에 체류하는 누구나 같은 수준의 안내를 받을 수 있다.